



Website Vulnerability Scanner Report

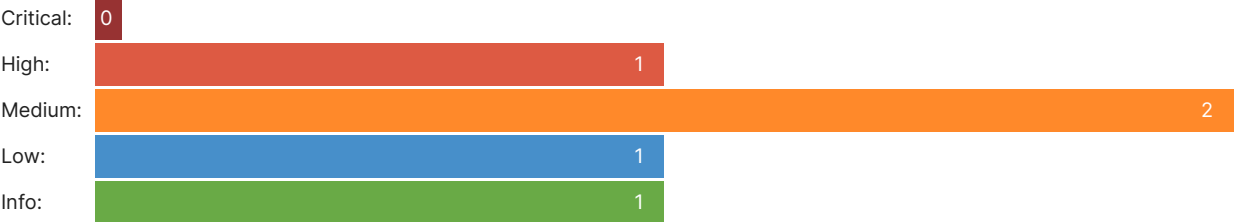
✓ <https://dev-brisurf.brins.co.id/BRISURF/CoveringValidation>

Summary

Overall risk level:

High

Risk ratings:



Scan information:

Start time: Sep 01, 2026 / 08:42:17 UTC+07
Finish time: Sep 01, 2026 / 08:42:43 UTC+07
Scan duration: 26 sec
Tests performed: 40
Scan status: Finished

Findings

Vulnerabilities found for php 7.4.30

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2024-3566	9.8	0.06883	0.93458	A command inject vulnerability allows an attacker to perform command injection on Windows applications that indirectly depend on the CreateProcess function when the specific conditions are satisfied.
CVE-2022-37454	9.8	0.05414	0.91966	The Keccak XKCP SHA-3 reference implementation before fdc6fef has an integer overflow and resultant buffer overflow that allows attackers to execute arbitrary code or eliminate expected cryptographic properties. This occurs in the sponge function interface.

CVE-2022-31630	6.5	0.02179	0.80712	In PHP versions prior to 7.4.33, 8.0.25 and 8.1.12, when using imageloadfont() function in gd extension, it is possible to supply a specially crafted font file, such as if the loaded font is used with imagechar() function, the read outside allocated buffer will be used. This can lead to crashes or disclosure of confidential information.
CVE-2022-31629	6.5	0.49336	0.98782	In PHP versions before 7.4.31, 8.0.24 and 8.1.11, the vulnerability enables network and same-site attackers to set a standard insecure cookie in the victim's browser which is treated as a `__Host-` or `__Secure-` cookie by PHP applications.
CVE-2022-4900	6.2	0.00367	0.29575	A vulnerability was found in PHP where setting the environment variable PHP_CLI_SERVER_WORKERS to a large value leads to a heap buffer overflow.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.49336

EPSS percentile : 0.98782

CISA KEV: False

CVE : [CVE-2024-3566](#), [CVE-2022-37454](#), [CVE-2022-31630](#), [CVE-2022-31629](#), [CVE-2022-4900](#)

CVSS V3 : 9.8

CWE : [CWE-1035](#)



Insecure cookie setting: missing Secure flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://dev-brisurf.brins.co.id/BRISURF/CoveringValidation	TSda182c79027	Set-Cookie: TSda182c79027=08da83dfadab2000fc4d2970967fd0a2e9312c6f4f6864dc245a72f8357d691137ca41d536441b3608b0a6be70113000fdc5a66b7f3405e89e445e02192f414a964a25be3fbab3f77c0782c1ab3ed16b64dfcfb65fa15e37846731ab38917193 Request / Response

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Insecure cookie setting: missing HttpOnly flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://dev-brisurf.brins.co.id/BRISURF/CoveringValidation	TSda182c79027	The server responded with Set-Cookie header(s) that does not specify the HttpOnly flag: Set-Cookie: TSda182c79027=08da83dfadab2000fc4d2970967fd0a2e9312c6f4f6864dc245a72f8357d691137ca41d536441b3608b0a6be70113000fdc5a66b7f3405e89e445e02192f414a964a25be3fbab3f77c0782c1ab3ed16b64dfcfb65fa15e37846731ab38917193 Request / Response

▼ Details

Risk description:

The risk is that an attacker who injects malicious JavaScript code on the page (e.g. by using an XSS attack) can access the cookie and can send it to another site. In case of a session cookie, this could lead to session hijacking.

Recommendation:

Ensure that the HttpOnly flag is set for all cookies.

References:

<https://owasp.org/www-community/HttpOnly>

Classification:CWE : [CWE-1004](#)OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#) Server software and technology found

UNCONFIRMED



port 443/tcp

Software / Version	Category
 PHP 7.4.30	Programming languages
 Sectigo	SSL/TLS certificate authorities
 HSTS	Security

 Details**Risk description:**

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:CWE : [CWE-200](#)OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#) Security.txt file is missing

CONFIRMED

port 443/tcp

URL
Missing: https://dev-brisurf.brins.co.id/well-known/security.txt

 Details**Risk description:**

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information

List of tests performed (40)

Port 443

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for website technologies
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for client access policies
- ✓ Scanned for robots.txt file
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission

- ✓ Scanned for sensitive data
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure
- ✓ Scanned for Session Token in URL
- ✓ Scanned for API endpoints
- ✓ Scanned for emails
- ✓ Scanned for missing HTTP header - Rate Limit
- ✓ Scanned for PEM-encoded private key material
- ✓ Scanned for partial PEM-encoded private key material

Scan parameters

target: https://dev-brisurf.brins.co.id/BRISURF/CoveringValidation
scan_type: Light
authentication: False

Scan stats

Unique Injection Points Detected: 1
URLs spidered: 1
Total number of HTTP requests: 10
Average time until a response was received: 372ms
